Tooltime. Penetration testing.

Disclaimer

Everything shown is to be used for educational purposes only. All Information exposed in this Presentation has the goal to teach you the techniques used by hackers in order to avoid their attacks. Please make sure before analyzing Applications that you have the Approval of the Owner/Author of the Applications you are analyzing. Hacking is a crime and I am not Responsible for the way you use it!

How it is happening?

Google

site:s3.amazonaws.com filetype:pdf commerzbank

All Maps News Images Videos More Settings Tools

About 1.580 results (0,42 seconds)

[PDF] Commerzbank AG, Commerzbank AG New York Branch - Internation…
https://s3.amazonaws.com/s3.../new-york-dept-of-financial-services-settlement.pdf
WHEREAS **Commerzbank** failed to maintain sufficient controls, policies, and procedures to ensure compliance with the Bank Secrecy Act and other anti-money ...

[PDF] x COMMERZBANK AG, Plaintiff - Amazon S3
s3.amazonaws.com/cdn.orrick.com/files/RMBSComplaint.pdf
Dec 23, 2015 - Plaintiff **Commerzbank** AG ("Plaintiff" or "**Commerzbank**"), by and through its attorneys, brings this action against Defendant The Bank of New ...

sir norman foster and partners commerzbank ... - Amazon AWS
https://l7g2r1k92kint.s3.amazonaws.com/Fe7199dfb7597a15b4b08f966522233-int.pdf
Legal sir norman foster and partners **commerzbank** frankfurt am eBook for free and you can read online at Online Ebook Library. Get sir norman foster and ...

[PDF] Commerzbank and AXA sign financing partnership for ... - Amazon A…
https://axa-prod.s3.amazonaws.com/www-axa-com%2Ff15911c8-fe41-4230-971f-e1...
Jun 6, 2013 - **Commerzbank** and AXA today announced a partnership to benefit medium sized corporates based in. Germany, Switzerland and Austria.

[PDF] Digital revolution in retail banking - Roland Berger
https://theartofservicelab.s3.amazonaws.com/.../Roland_Berger_Digital_Revolution_in...
Feb 26, 2015 - Source: **Commerzbank**; Deutsche Bank; Postbank; Sparkasse; Volks-/

When Attackers Target Vulnerabilities

Attacker creates exploits to target software vulnerability

1. Exploits may arrive via:
- Attachment to email messages
- Comproised websites
- Social networking sites

OR

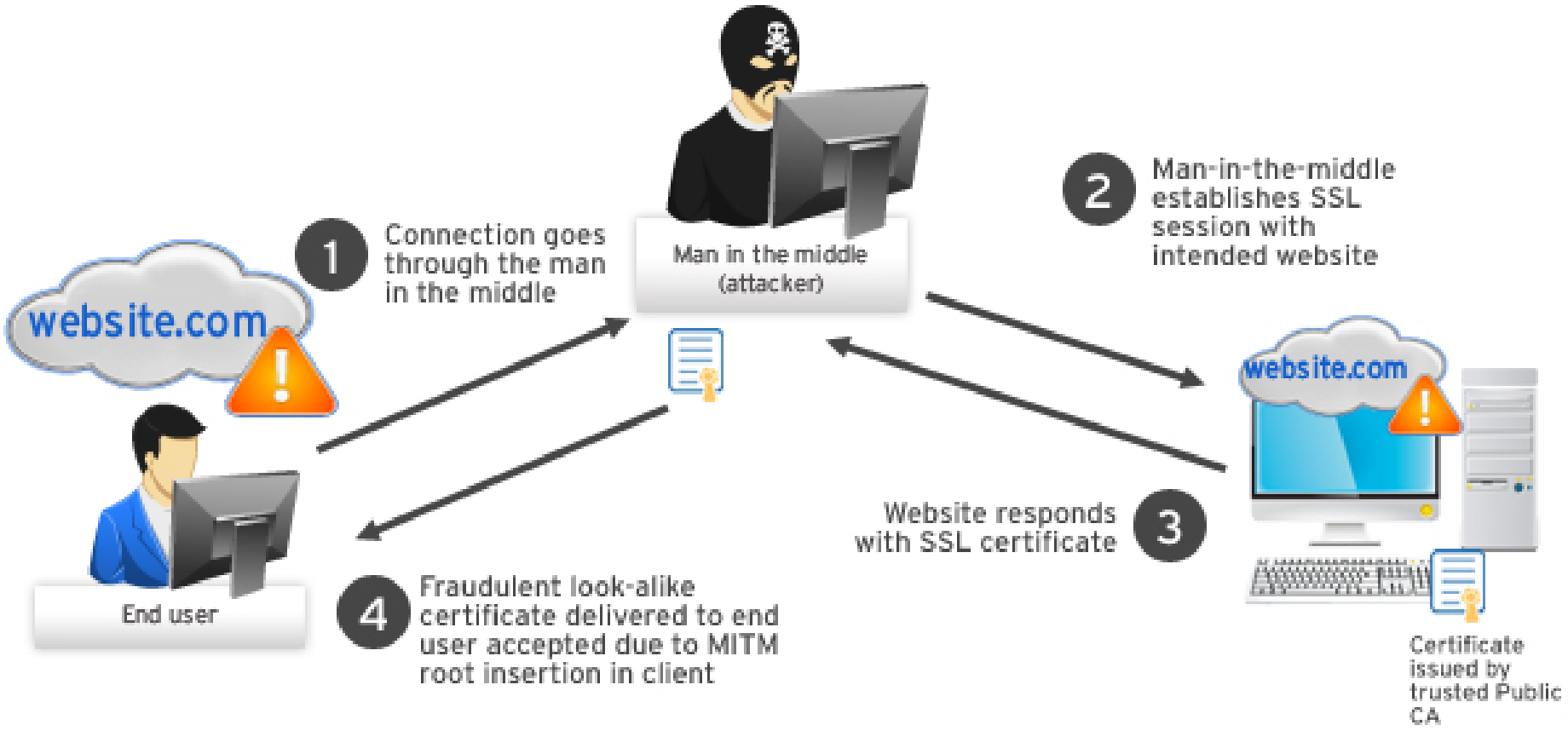
2. Attacker may directly target vulnerable servers

Users are lured into executing the exploit via social engineering techniques

OR

Exploits may drop malware onto the vulnerable system or allow attackers remote control

MiTM


website.com
1
Connection goes through the man in the middle
Man in the middle (attacker)
2
Man-in-the-middle establishes SSL session with intended website
website.com
Website responds with SSL certificate
3
End user
4
Fraudulent look-alike certificate delivered to end user accepted due to MITM root insertion in client
Certificate issued by trusted Public CA

Tools

Nessus® vulnerability scanner

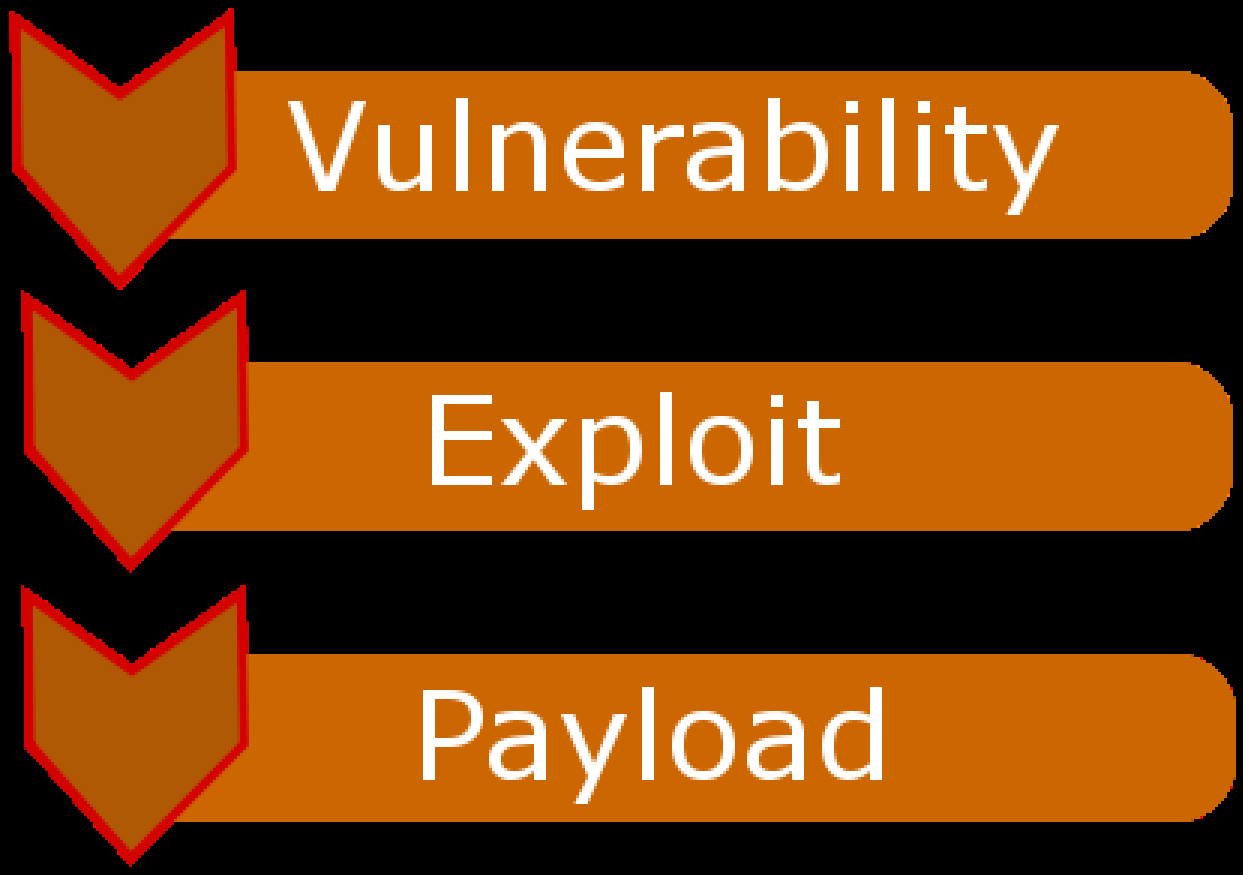
NMAP

metasploit®

ipmitool

snmpwalk

Burp Scanner


Vulnerability
Exploit
Payload

Set Exploit

- use [exploit_name]

Set Exploit Options

- show options
- set [option_name] [value]

Set Payload

- show payloads
- set payload [payload_name]

Set Payload Options

- show options
- set [option_name] [value]

Exploit

- exploit

MS08-067: Microsoft Windows Server Service Crafted RPC Request Handling Remote Code Execution

34477 (1) - MS08-067: Microsoft Windows Server Service Crafted RPC Request Handling Remote Code Execution (958644) (uncredentialed check)

Synopsis

Arbitrary code can be executed on the remote host due to a flaw in the 'Server' service.

Description

The remote host is vulnerable to a buffer overrun in the 'Server'
service that may allow an attacker to execute arbitrary code on the remote host with the 'System' privileges.

See Also

http://technet.microsoft.com/en-us/security/bulletin/ms08-067

Solution

Microsoft has released a set of patches for Windows 2000, XP, 2003, Vista and 2008.

Risk Factor

Critical

CVSS Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

CVSS Temporal Score

8.7 (CVSS2#E:H/RL:OF/RC:C)

STIG Severity

I

References

BID	31874
CVE	CVE-2008-4250
XREF	OSVDB:49243
XREF	MSFT:MS08-067
XREF	IAVA:2008-A-0081
XREF	CWE:94

Exploitable with

CANVAS (true)Core Impact (true)Metasploit (true)

HP Data Protector Arbitrary Command Execution

79233 (1) - HP Data Protector 'EXEC_INTEGUTIL' Arbitrary Command Execution

Synopsis

The remote host is affected by an arbitrary command execution vulnerability.

Description

Nessus was able to execute an operating system command on the remote HP Data Protector installation by sending a specially crafted 'EXEC_INTEGUTIL' packet to the HP Data Protector service.

See Also

http://www.zerodayinitiative.com/advisories/ZDI-14-344/

Solution

A patched version is not currently available. As a workaround, enable Encrypted Control Communications (ECC) services on the cell server and all of the clients in the cell.

Risk Factor

Critical

CVSS Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

CVSS Temporal Score

10.0 (CVSS2#E:ND/RL:U/RC:C)

References

BID	70244
XREF	OSVDB:112582
XREF	EDB-ID:35034

Plugin Information:

Publication date: 2014/11/13, Modification date: 2014/11/13

IPMI Cipher Suite Zero Authentication Bypass

68931 (1) - IPMI Cipher Suite Zero Authentication Bypass

Synopsis

The remote IPMI service is affected by an authentication bypass.

Description

The IPMI service listening on the remote system has cipher suite zero enabled, which permits logon as an administrator without requiring a password. Once logged in, a remote attacker may perform a variety of actions, including powering off the remote system.

Note that this plugin checks generically for the Cipher Suite Zero authentication bypass vulnerability using a number of common accounts.

See Also

http://fish2.com/ipmi/cipherzero.html

Solution

Disable cipher suite zero or limit access to the IPMI service.

Risk Factor

Critical

CVSS Base Score

10.0 (CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C)

CVSS Temporal Score

9.5 (CVSS2#E:F/RL:U/RC:ND)

References

BID	61001
BID	68499
CVE	CVE-2013-4782

IPMI v2.0 Password Hash Disclosure

80101 (2) - IPMI v2.0 Password Hash Disclosure

Synopsis

The remote host supports IPMI version 2.0.

Description

The remote host supports IPMI v2.0. The Intelligent Platform Management Interface (IPMI) protocol is affected by an information disclosure vulnerability due to the support of RMCP+ Authenticated Key-Exchange Protocol (RAKP) authentication. A remote attacker can obtain password hash information for valid user accounts via the HMAC from a RAKP message 2 response from a BMC.

See Also

http://fish2.com/ipmi/remote-pw-cracking.html

Solution

There is no patch for this vulnerability; it is an inherent problem with the specification for IPMI v2.0. Suggested mitigations include :

- Disabling IPMI over LAN if it is not needed.

- Using strong passwords to limit the successfulness of off-line dictionary attacks.

- Using Access Control Lists (ACLs) or isolated networks to limit access to your IPMI management interfaces.

Risk Factor

High

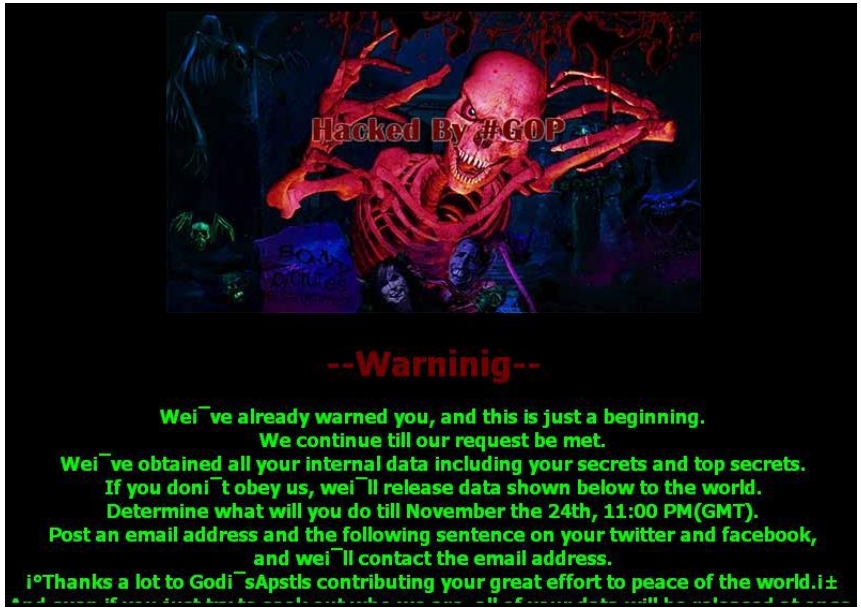
CVSS Base Score

7.8 (CVSS2#AV:N/AC:L/Au:N/C:C/I:N/A:N)

CVSS Temporal Score

7.8 (CVSS2#E:ND/RL:U/RC:ND)

HTTP://
SENDS OUT
PDF
EXPLOITS
EXECUTES
CONNECTS TO



Commerzbank AG
www.commerzbank.com

SERGEY EGOROV

Penetration testing team